



A cybersecurity risk quantification and classification framework for informed risk mitigation decisions

Amir Zadeh^{a,*}, Brandon Lavine^a, Hamed Zolbanin^b, Donald Hopkins^a

^a Department of Information Systems and Supply Chain Management, Raj Soin College of Business, Wright State University, Dayton, OH 45435, USA

^b Department of MIS, OSC and Business Analytics, College of Business, University of Dayton, Dayton, OH 45469, USA

ARTICLE INFO

Keywords:

Cybersecurity
Information security
Data breach severity classification
Content analysis
Risk mitigation
Likelihood impact matrix analysis

ABSTRACT

Data breaches have been causing havoc for many years and continue to rise, demanding a more comprehensive framework to assess their severity. This study proposes a cybersecurity risk quantification and classification framework, addressing a significant research gap in breach severity evaluation. The study has two main objectives: to present a structured model for precise breach severity assessment, and to apply this model to real-world data breaches for practical insights. To achieve these objectives, we utilize a content analysis methodology to gauge severity of data breaches. This is followed by a robust likelihood impact matrix analysis, serving as a decision analytics tool, to effectively quantify potential risks. The integration of these approaches yields a more comprehensive and nuanced evaluation for assessing data breach severity. The proposed framework is then applied to data breaches gathered from Standard & Poor's (S&P 500) organizations, revealing hacking and loss/theft of portable media as the breach types with the highest impact and probability. Drawing from these insights, our study suggests effective strategies to mitigate data breach risks for organizations. The implications of our research findings offer valuable contributions to both academic research and practical cybersecurity risk management.

1. Introduction

In recent times, the financial repercussions of data breaches have reached staggering proportions, with the average breach cost escalating to \$4.35 million according to a report by IBM Security¹ [1]. The average cost of a breach for an organization amounts to \$3.86 million, as indicated by Ponemon [2], with data breaches being particularly costly in the United States. The United States has witnessed a significant surge in annual data breach counts, amplifying the potential consequences for both organizations and individuals [3]. These breaches not only lead to substantial financial losses but also trigger legal actions and fines [4].

Despite the imperative to safeguard data, breaches continue to pose significant challenges, especially for small businesses that may face bankruptcy within few years of an incident [5]. Organizations are compelled to interact with stakeholders, emphasizing confidentiality, integrity, and availability of information systems [6]. Cybersecurity breaches can adversely impact market value, stock price, and returns [7], necessitating immediate response. However, quantifying breach severity and its diverse impact remains a complex task [8].

Most conventional risk assessment methods utilized in information security rely on experts' expertise and subjective understanding. They primarily center on basic scales or measurements to evaluate the potential adverse consequences of data breach incidents. One such widely adopted approach involves the use of basic three-level ordinal scales, which categorize breaches as "low", "medium", or "high" in severity. Another class of methods rely on probabilistic risk analysis to quantify breach impact using a ratio scale, often expressed in monetary terms. Whether these assessments are conveyed as ordinal or ratio values, the process of estimating impact plays a pivotal role in effective risk management [9]. Existing research often falls short of adopting a comprehensive perspective that simultaneously considers both the impact (i.e., severity) and likelihood (i.e. frequency) of breaches. This limitation leads to insufficient evaluations of breach severity, leaving organizations ill-equipped to adequately address their potential consequences. This research gap has been acknowledged in the extant literature [10], with an increasing recognition that the extent of severity notably influences the strategies that firms adopt in response to such incidents [11].

* Corresponding author.

E-mail addresses: amir.zadeh@wright.edu (A. Zadeh), lavine.4@wright.edu (B. Lavine), hmzolbanin@udayton.edu (H. Zolbanin), donald.hopkins@wright.edu (D. Hopkins).

URLs: <https://people.wright.edu/amir.zadeh> (A. Zadeh), https://udayton.edu/directory/business/mis_osc_and_business_analytics/zolbanin-hamed.php (H. Zolbanin), <https://people.wright.edu/donald.hopkins> (D. Hopkins).

¹ <https://www.statista.com/statistics/273550/data-breaches-recorded-in-the-united-states-by-number-of-breaches-and-records-exposed/>

The purpose of this study is to bridge the gap by presenting a framework for a more comprehensive assessment of data breaches. This is achieved through the implementation of a structured model, designed to systematically quantify both the likelihood and impact of data breaches. We present a cybersecurity risk quantification and classification framework, which effectively addresses a noteworthy gap in the evaluation of breach severity. More specifically, our study encompasses two primary objectives: firstly, to present a structured model to enable precise assessment of breach severity; and secondly, to apply the practical application of this model to real-world data breaches, yielding valuable insights. To achieve these objectives, our methodology involves employing content analysis to gauge data breach severity, bolstered by a robust analysis utilizing a likelihood-impact matrix as a strategic decision analytics tool for quantifying potential breach risks. We amalgamate descriptive, diagnostic, and predictive modeling techniques to evaluate breach severity and organizational responses. Through an analysis of historical breach data and the development of a comprehensive assessment framework, our research contributes to identifying organizational risks and opportunities by leveraging data patterns. Our findings demonstrate that this integration yields a comprehensive and nuanced evaluation, significantly enhancing our capacity to assess breach severity. We illustrate the efficacy of our proposed framework using a dataset comprising breaches from Standard & Poor's (S&P 500) organizations. By quantifying breach severity, organizations can prioritize their cybersecurity efforts, allocate resources effectively, and implement security measures aligned with the risk level posed by different breach types. This approach empowers organizations to address the most severe breaches first, mitigating their impact and enhancing their ability to safeguard sensitive data.

Therefore, this study makes four primary contributions to the cybersecurity field. Firstly, we propose an assessment framework to study data breaches, which adds to the existing literature on cybersecurity. Secondly, we provide a detailed analysis of S&P 500 data breaches over the past fifteen years, examining their likelihood and impact, and offering valuable insights into the trends and patterns of these incidents. Thirdly, we contribute to the decision analytics literature by demonstrating how decision analytics methods such as likelihood-impact analysis can help organization assess the potential risks associated with different data breach scenarios. By quantifying the likelihood of a breach and its potential impact, decision-makers can prioritize their actions and resources based on the level of risk posed by each scenario. Lastly, we provide an interactive visualization dashboard that enables us to explore and categorize data breaches based on their severity.

The next section presents a review of relevant literature that informed this study. The subsequent section details the research method used to identify the characteristics of data breaches. Next, we present the analysis and discussion sections, which outline the characterization of cybersecurity data breaches and the development of potential strategies to mitigate them. The paper will conclude with a summary of results and suggestions for future research.

2. Prior literature

Previous studies on cybersecurity have examined a range of issues related to both organizational and operational aspects. This includes identifying potential threats or vulnerabilities [4,12]; exploring mechanisms behind cybersecurity breaches and attacks [13,14]; developing frameworks or models for assessing, predicting, and mitigating cybersecurity attacks [15–20]; investigating the social, economic, and financial impacts of data breaches [21–23]; and analyzing the routines, structures, and capabilities necessary for effective cybersecurity responses by organizations [24,25]. For instance, Gordon, Loeb, Sohail, Tseng and Zhou [26] discussed the importance of leadership processes, organizational structures, and capital allocations in managing cybersecurity through the installation of Chief Information Security Officer (CISO) positions within organizations. Jeyaraj and Zadeh [27] investigated the

roles of institutional pressures by examining how mimetic pressures, normative pressures, and coercive pressures influence organizational cybersecurity responses over time. Tavarna, Nasr, Ahmadabadi, Amiri and Mina [20] presented a practical approach employing multi-criteria decision-making to assess and choose appropriate blockchain and Internet of Things platforms for supply chain networks. This method considers criteria interdependencies and experts' preferences, showcasing the efficacy of these technologies in preventing data breaches and cyber-attacks within supply chain networks.

The rapid expansion of cyberspace has led to an ongoing and pressing challenge in devising effective strategies to combat the escalating threat of cybersecurity breaches. These breaches pose a significant risk to the security and confidentiality of personally identifiable information (PII), encompassing a wide range of sensitive data such as user accounts, names, addresses, social security numbers, financial records, passwords, and medical histories. The potential malicious use of this information by cybercriminals underscores the critical importance of safeguarding PII from unauthorized access and exploitation [28,29]. Within this landscape, the deployment of advanced analytics tools offers a promising avenue for addressing the multifaceted nature of cybersecurity challenges. Descriptive, diagnostics and predictive analytics, in particular, emerge as viable solutions that leverage data-driven insights to enhance cyber defense strategies. Predictive diagnostics entail the proactive identification of potential vulnerabilities and threats by analyzing historical data patterns and trends [30,31]. This has prompted a demand for further research into the potential of big data driven analytical models within the realm of cybersecurity, given their capacity to facilitate informed decisions, anticipate and proactively mitigate potential breaches, thereby fortifying overall security measures [32].

Data breaches can be due to unintended disclosure (DISC), hacking or malware (HACK), fraud involvement around account information (CARD), insiders accessing sensitive information (INSD), loss or stolen assets or records (PHYS), loss of portable media (PORT), and loss of digital equipment like a desktop computer (STAT) [6]. Unintended disclosure (DISC) refers to the accidental disclosure of sensitive information to unintended parties, with the impact on businesses depending on the nature of the information disclosed. Hacking or malware (HACK) involves the use of unauthorized access to gain entry to a system or network, with the consequences varying based on the level of access gained and the sensitivity of the information obtained [33]. Fraud involving account information (CARD) is characterized by the unauthorized access of sensitive account information, such as credit card or bank account details, and the use of this information for fraudulent activities. The extent of the breach depends on the amount of information accessed and the extent of the fraud. Insiders accessing sensitive information (INSD) involves the unauthorized access of sensitive information by authorized personnel, such as employees, which can have significant repercussions depending on the level of access and the sensitivity of the information obtained. Loss or theft of assets or records (PHYS), portable media (PORT), and digital equipment (STAT) occur when physical assets or records, such as laptops, files, or paper records; portable storage devices, such as USB drives; or a desktop computer are lost or stolen [6,34,35]. The impact of these types of breaches depends on the sensitivity of the information stored on the assets, records, media, or devices. The breaches are also categorized by the type of industry and include Business, Financial and Insurance services (BSF), Business, Retail/Merchant entities (BSR), Educational Institutions (EDU), Government and Military (GOV), Healthcare and Medical providers (MED), Nonprofit (NGO), and other businesses category (BSO) [6].

Mandatory breach reporting laws have been enacted in all 50 states in the United States, as well as in other countries such as Australia, the UK, and the EU. The introduction of mandatory reporting requirements has made breach incidents more visible to the public [36]. Chen, Henry and Jiang [37] investigated managers' decisions regarding the disclosure of risk factors for firms and concluded that these risk

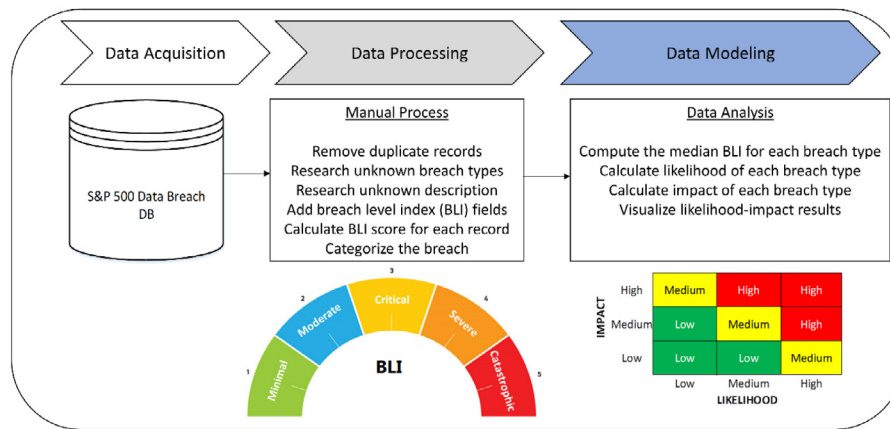


Fig. 1. Research framework.

factor disclosures provide valuable information. In response to a data breach, decision-makers must take appropriate steps, including contacting a legal expert before speaking to anyone else [38]. Additionally, there are minimum thresholds for the number of records that must be compromised to trigger a mandatory reporting requirement [39–41].

The severity of a breach is a multifaceted phenomenon influenced by a myriad of interconnected factors, each contributing to the overall impact and consequences of the breach [42]. These factors encompass a wide range of elements, including the nature and sensitivity of compromised data, the scope of individuals affected, the duration of the breach, the effectiveness of security measures in place, and the potential financial and reputational damages incurred [43]. Moreover, the context in which the breach occurs, such as the industry [44], regulatory environment [45], and geographic location [46], can further amplify or mitigate its severity. Additionally, the speed and effectiveness of incident response efforts [47], as well as the organization's ability to communicate and mitigate the breach's aftermath [48], play a crucial role. Recognizing the intricate interplay of these factors is essential for accurately assessing and comprehending the true severity of a breach. Failure to consider these nuances can lead to an inadequate understanding of the breach's implications, hindering effective response strategies and risk management measures. Therefore, a comprehensive and holistic approach that carefully examines these diverse factors is imperative to accurately gauge the severity of a breach and guide appropriate actions for mitigation and recovery.

The breach level index (BLI), developed by Stiennon [49], is a widely used metric for measuring the severity of a data breach. It measures the severity of a data breach based on four weighted variables (i.e., number of records, type of data, source of the breach, and whether or not the data has been used for nefarious purposes) and will help organizations better understand the impact of data breaches on their operations [50]. In this study, we utilize the BLI to assess the probability and severity of potential data breaches across diverse industries. By applying the BLI to analyze breach types and categories, decision-makers can gain insights into cyber threats, shaping effective risk mitigation strategies. Our approach not only identifies data breach likelihood and impact of but also enables organizations to proactively steer and alleviate cybersecurity risks.

3. Research methodology

Our research methodology consists of four major phases: data acquisition, data processing, data modeling, and data analysis [51]. The analytical methodology used in this study is depicted in Fig. 1, illustrating how we identified the characteristics of data breaches. Our framework consists of two components: risk quantification and risk classification. Our framework first leverages a breach index formula to characterize risks based on past breach incidents among S&P 500

organizations. After quantification, further assessment is performed to classify cyber risks in terms of likelihood and impact.

Data Acquisition

The database of data breaches maintained by the Privacy Rights Clearinghouse² was accessed to obtain data on cybersecurity breaches previously encountered by the top 500 organizations as listed in S&P 500 rankings [52]. The original dataset was the source of about 9,000 records from the state attorney general and the U.S. Department of Health and Human Services. Acquiring a list of breaches in the top S&P 500 companies dated back to 2005 and excluding all the companies that were not on the S&P 500 helped narrow down the data to a manageable size for in-depth content analysis.

Data preprocessing

Our dataset was classified by breach and institution type, number of records exposed, location, and some description of the situation surrounding each data breach. The breaches were organized by types (e.g., unintended disclosure, hacking or malware, payment card fraud, malicious insider, physical loss, portable device, stationary device, unknown). By reviewing the description of the incident, the breach type, and the number of compromised records in the breach, a large number of duplicate records and irrelevant data were removed. This gave us a true number of data breaches over the last 15 years. This manual process allowed for a better understanding of data breaches and how they resembled each other. Our final dataset included 469 data breaches between 2005 and 2019 from different industries. Accounting for duplicates, we found that almost 1.5 billion records were compromised within the S&P 500 throughout the years.

The manual process began with sorting by the company name. We started by cleaning similar company names; for example, Target Inc. and Target Company. This required research to see if the companies were indeed the same and that the date, type, and description of the breach were indeed a duplicate. This process was done for 30 records, and as a result, over 100 million records of breaches were removed due to redundancy. Also, additional research was done to make sure that companies were not bought out or the company name had not changed.

In addition, several breaches had an “unknown” type. Replacing the unknowns with a definite data breach type would make our results more accurate. This was a significant aspect of our manual data cleaning process, which required considerable time and thorough investigation. A detailed examination was conducted to ascertain the actual cause of each breach labeled as “unknown” in the original dataset. It is worth noting that automating this process proved challenging due to the absence of a standardized approach. For some breaches lacking a definitive cause, they were categorized as *unknown*. In instances

² <https://privacyrights.org/data-breaches>

Table 1
Descriptive statistics — (Means–SDs in parentheses).

Industry type	BSF	BSO	BSR	EDU	GOV	MED	NGO	Overall avg. (SD)
CARD	5.44 (1.29)		5.33 (0.00)					5.43 (1.19)
DISC	3.17 (2.59)	4.04 (3.11)	3.69 (3.74)	1.60 (2.77)	2.59 (3.66)	2.68 (2.25)		3.14 (2.74)
HACK	5.98 (2.38)	5.95 (1.73)	6.49 (2.68)	3.65 (0.00)		4.33 (1.83)	3.28 (0.00)	5.63 (2.27)
INSD	4.70 (1.83)	5.12 (1.09)	3.86 (1.23)			3.81 (1.63)		4.33 (1.58)
PHYS	3.91 (0.26)	3.70 (0.00)	3.98 (0.00)	3.28 (0.00)	2.60 (0.00)	3.90 (1.26)		3.82 (1.14)
PORT	4.52 (1.90)	4.96 (0.90)	4.45 (1.42)		4.30 (1.98)	4.71 (1.45)		4.66 (1.47)
STAT	6.07 (1.14)	5.75 (0.00)	2.72 (0.00)			5.82 (0.11)		5.37 (1.47)
UNKN	3.52 (0.00)	6.51 (2.08)						5.01 (1.40)
Overall Avg. (SD)	4.67 (2.17)	5.13 (2.01)	4.89 (2.61)	2.34 (2.21)	3.45 (1.93)	3.72 (1.93)	3.28 (0.00)	4.43 (2.23)

where breach descriptions did not provide sufficient information for classification, we conducted comprehensive research using additional sources to determine the true nature of the breach incident. To provide illustrative examples of our data cleaning and classification efforts, we have included three specific breach cases, along with the resources utilized for their type determination, in [Appendix B](#).

Data Modeling

The BLI method, as formulated by Stiennon [49] served as the tool for assessing data breach severity. According to Stiennon [49], the severity of a breach depends on four weighted values: number of records (N), type of data (t), source of the breach (s), and whether or not the data has been used for nefarious purposes (A). The BLI is formulated as follows:

$$BLI = \log_{10}(N * t * s * A)$$

where the type of data (t) involved in a breach can be categorized based on its nature and potential impact. It can range from relatively less sensitive data like email addresses or affiliations ($=1$), to moderately sensitive data like account access credentials (e.g., username/passwords to social media or websites) ($=2$), and further to highly sensitive data such as financial access credentials (e.g., bank account details or credit card information) ($=3$). Additionally, it includes identity theft information that can be used to impersonate individuals ($=4$), and even existential data that holds significant value for national security or poses a threat to business survival ($=5$). Data breaches (s) can occur through various sources, each carrying different levels of risk. These sources include situations where data is compromised due to lost devices such as laptops or USB thumb drives ($=1$), theft of devices ($=2$), actions of malicious insiders ($=3$), attacks by malicious outsiders ($=4$), and even state-sponsored espionage ($=5$). Furthermore, the stolen data (A) can be utilized to cause harm or theft at different levels. There are scenarios where no immediate action was taken on the stolen data ($=1$), instances where embarrassing or harmful information was published on platforms like WikiLeaks or hacker blogs ($=5$), and more severe cases where stolen financial identity data was exploited to fraudulently obtain funds or apply for loans ($=10$).

After the weighted values for the number of records, data type, source, and whether the data has been used to steal identity or cause harm were determined for each breach event in our database, the BLI score was calculated to measure the severity of the breach. The BLI score was then used to categorize breaches into one of five breach severity levels: minimal (1–2.9), moderate (3–4.9), critical (5–6.9), severe (7–8.9), and catastrophic (9–10). [Appendix A](#) includes illustrations of multiple categorized breach examples along with their corresponding BLI score calculations.

Data Analysis

In this section, we present an overview of the mean and standard deviation of the breach level index for various types of data breaches across different industries. [Table 1](#) shows a detailed breakdown of the distribution of the breach level index across different industries. The breach level index is a measure of the severity of the breach, with a higher index indicating a more severe breach. The industries included in the table are BSF, BSO, BSR, EDU, GOV, MED, and NGO. The results

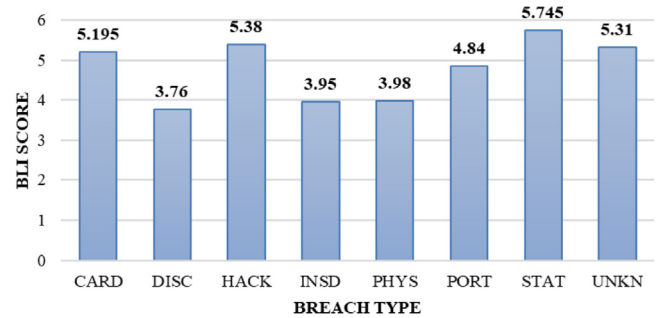


Fig. 2. BLI scores by industry.



Fig. 3. BLI scores by breach type.

show that the mean breach level index across all industries and breach types is 4.43, with a standard deviation (SD) of 2.23. This suggests that the mean breach level index varies across different types of data breaches and industries. The highest mean BLI scores are for HACK (5.63), CARD (5.43), and STAT (5.37) breaches, indicating that these types of breaches are generally more severe in terms of their potential impact across industries. For instance, the mean breach level index for the HACK breach type is highest in the BSR industry (6.49). Similarly, the mean breach level index for the INSD breach type is highest in the BSO industry (5.12). The lowest mean BLI scores are for DISC (3.14), PHYS (3.82), and INSD (4.33) breaches, indicating that these types of breaches are generally less severe in terms of their potential impact across industries.

[Fig. 2](#) illustrates the BLI scores by industry, allowing for a side-by-side comparison of risk levels among different industry sectors. Furthermore, [Fig. 3](#) displays the BLI scores categorized by breach type, enabling a visual analysis of the relative impact of each data breach type.

Our analysis also suggests that the standard deviation of the breach level index varies across different types of data breaches and industries, indicating different levels of severity for security breaches in each category. For example, the mean BLI score for HACK breaches ranges from 3.28 in the NGO industry to 6.49 in the BSR industry. In addition, the BSO industry stands out by having a relatively high mean BLI score

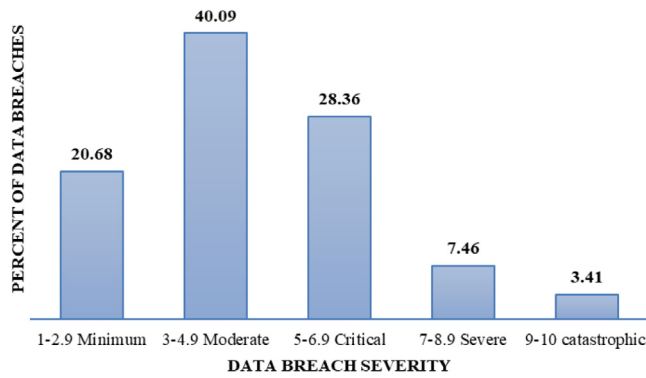


Fig. 4. Number of data breaches based on the severity level.

Table 2
Regression results.

Variable	Regression model
<i>Constant</i>	2.13 (12.60)***
BSF — Business, Financial, and Insurance Sector	0.37 (1.91)*
BSR — Business, Retail/Merchant Sector	0.41 (2.04)**
EDU — Educational Institution Sector	-0.26 (-.67)
MED — Healthcare, Medical Sector	0.05 (0.27)
NGO — Nonprofits Sector	-0.49 (-0.62)
BSO — Business, Other Sectors	0.58 (3.05)***
Breach Type — Unintended disclosure (DISC)	-0.49 (-3.68)***
Breach Type — Hacking or malware (HACK)	0.35 (2.68)***
Breach Type — Payment Card Fraud (CARD)	0.23 (0.79)
Breach Type — Insider (INSD)	-0.26 (-1.71)*
Breach Type — Physical loss (PHYS)	-0.23 (-1.20)
Breach Type — Portable device (PORT)	-0.16 (-1.21)
Breach Type — Stationary device (STAT)	0.33 (0.67)
Breach Type — Unknown (UNKN)	0.12 (0.19)
R ²	0.18
Model F	4.77***

*** p < 0.01.

** p < 0.05.

* p < 0.10.

Dependent variable: Breach Severity

Each cell contains the b-coefficient and the t-statistic in parentheses.

N = 469.

for DISC breaches (4.04) compared to other industries, while the EDU industry stands out by having a relatively low mean BLI score for all breach types. Finally, the UNKN breach type has a limited number of data points and varies widely across industries, indicating a need for further investigation.

Fig. 4 displays a histogram of the percentage of data breaches for each level of severity. It highlights the fact that most data breaches belong to the moderate and critical categories. We performed a linear regression analysis to explore the relationship between the Breach Level Index (BLI) – our measure of breach severity – and the industry sector and breach type, which we treated as independent variables. Our regression model was structured as follows:

$$BLI = \beta_0 + \beta_1 * Industry + \beta_2 * Breach Type + \epsilon$$

Here, BLI represents the dependent variable, capturing the severity of data breaches. The categorical predictor variables, Industry and Breach Type, were used to assess how different sectors and types of breaches contribute to variations in breach severity. The coefficients β_0 , β_1 , and β_2 were estimated to quantify the impact of each predictor variable, and ϵ accounted for unobserved factors. The outcomes of our regression analysis are presented comprehensively in Table 2.

The regression model provides some insights into the factors that are associated with the severity of a data breach. Industry sectors BSF and BSO are associated with higher severity of data breaches, while NGO is associated with lower severity. Breach types DISC and INSD are associated with lower severity of data breaches, while breach types HACK

Table 3

Occurrences and severity of breaches by type.

Breach type	Count	Median BLI
CARD	14	5.195
DISC	103	3.760
HACK	126	5.380
INSD	70	3.950
PHYS	35	3.980
PORT	92	4.840
STAT	10	5.745
UNKN	19	5.310
Total	469	4.440

Table 4

Likelihood and Impact Matrix for Breach Types.

Breach type	Probability	Impact	Risk
CARD	0.029978587	5.195	0.155739
DISC	0.220556745	3.760	0.829293
HACK	0.269807281	5.380	1.451563
INSD	0.149892934	3.950	0.592077
PHYS	0.074946467	3.980	0.298287
PORT	0.197002141	4.840	0.95349
STAT	0.021413276	5.745	0.123019
UNKN	0.03640257	5.310	0.193298

and STAT are associated with higher severity. Our regression model explains only 18% of the variance in the severity of data breaches, which suggests that there could be other factors that impact the severity of data breaches that are not captured in this model.

To construct a likelihood and impact matrix, we analyzed the frequency of each breach type and determined the median BLI based on the number of times a breach type occurred within the dataset. Table 3. Occurrences and Severity of Breaches by Type displays the frequency and severity of different breach types, as indicated by the median BLI scores.

Next, we calculated the probability of each breach type by dividing its count by the total number of breaches in the dataset. The impact was determined by taking the median of the BLI scores. The results of the likelihood and impact analysis are presented in Table 4. The results suggest that the breach type with the highest probability is HACK (26.98%), followed by DISC (22.06%) and PORT (19.70%). The breach type with the lowest probability is STAT (2.14%). In terms of impact, the highest impact score is associated with HACK (5.66), followed by CARD (5.43) and STAT (5.37). The breach type with the lowest impact score is DISC (3.14%).

By combining the probability and impact scores, organizations can prioritize their efforts to mitigate the risk of data breaches. To determine the risk score linked to each breach type, we further computed the product of the assessed likelihood and impact. Our results suggest that a breach type with a high probability and high impact (such as HACK) would be considered a high priority for mitigation efforts, while a breach type with a low probability and low impact (such as STAT) may not require significant resources for mitigation.

Based on this result, we performed a quadrant analysis to categorize the different types of data breaches based on their impact and probability. Fig. 5 provides a visual representation of the risk levels associated with different types of data breaches based on their likelihood and impact scores. The quadrant chart categorizes the breaches into four categories, allowing organizations to easily identify which breaches require the most immediate attention.

High Impact/High Probability: This category includes breach types that have a high likelihood of occurring and could have a severe impact on the organization. Since HACK has the highest impact score and is also the most probable breach type, it falls into this category.

Low Impact/High Probability: This category includes breach types that have a high likelihood of occurring but may not have a significant

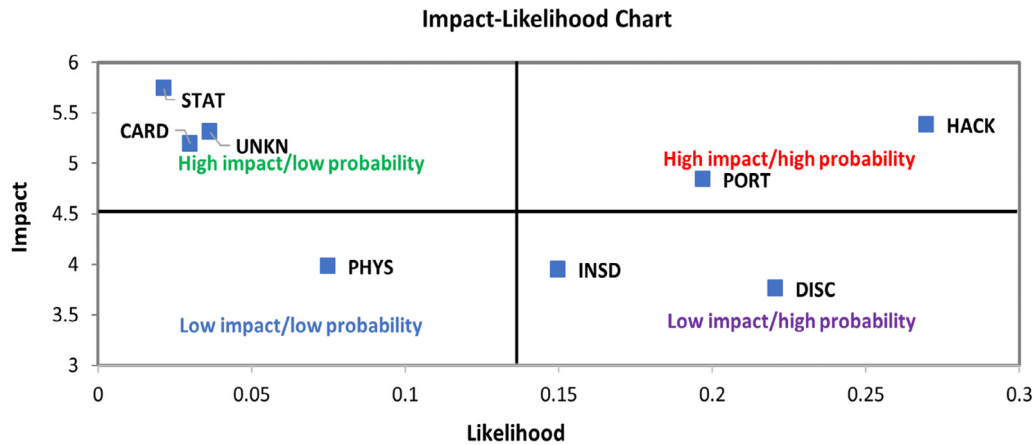


Fig. 5. Likelihood-impact risk matrix.

impact on the organization. DISC and INSD fall into this category as they have high probability scores but relatively low impact scores.

Low Impact/Low Probability: This category includes breach types that have a low probability of occurring and may not have a significant impact on the organization. PHYS falls into this category as they have both low probability and low impact scores.

High Impact/Low Probability: This category includes breach types that have a low likelihood of occurring but could have a severe impact on the organization. CARD, STAT and UNKN fall into this category as they have relatively low probability scores but high impact scores.

Finally, we examined the frequency and the number of breaches with compromised records for each type of breach. While a breach refers to unauthorized access or intrusion into a system or network, the compromise of records refers to the actual unauthorized disclosure or acquisition of sensitive information.

Table 5 presents the results of this analysis. Among all breach types, the most frequent type of breach was HACK with 126 breaches. However, breach type PHYS stands out with the highest percentage of compromised breaches. Out of a total of 35 breaches in the physical loss category, 26 incidents resulted in compromised records, accounting for a significant 74% of all breaches in this category. While physical loss breaches may occur less frequently, they can have a greater impact in terms of the number of compromised breaches. This finding underscores the severity and impact of physical loss breaches, as a substantial majority of such incidents led to the compromise of sensitive information. It emphasizes the importance of implementing robust security measures to mitigate the risks associated with physical breaches.

It is also worth noting that out of a total of 469 breaches, 272 of them resulted in compromised records was, highlighting the possibility of breaches occurring without any records being compromised. In many cases, a breach may be detected and addressed before any records are compromised. This could happen due to security measures, quick response, or other factors that prevent the unauthorized access from resulting in the actual compromise of records. To provide further insights into the dataset used in this study, we recommend readers to explore our interactive Tableau dashboard, which was specifically designed to analyze breach trends and patterns and can greatly enhance the reader's understanding of the study's findings.³

4. Discussion

This study presents a comprehensive framework for quantifying and classifying cybersecurity risks using a likelihood-impact analysis matrix. Previous research has predominantly concentrated on employing

Table 5

Data breach statistics by breach type.

Type of breach	Compromised breach count	Total breach count	Percent of compromised breaches
PHYS	26	35	74%
PORT	66	92	71%
STAT	6	10	60%
CARD	8	14	57%
INSD	39	70	55%
HACK	69	126	54%
UNKN	11	19	52%
DISC	47	103	45%
Total	272	469	58%

binary breach variables, primarily distinguishing between breach occurrence or non-occurrence, without adequately considering different levels of severity. In this paper, we present a framework that effectively incorporates multiple breach specifications to capture and account for these distinct variations in severity. By assessing the severity of data breaches based on their likelihood and potential impact, our framework enables organizations to prioritize their response efforts and allocate their resources more effectively. The proposed framework allows organizations to categorize risks based on their severity and take necessary actions to mitigate the risks with the greatest potential impact. By focusing on high-likelihood, high-impact risks, organizations can prioritize their resources and ensure they are prepared to respond to the most critical threats. This can help an organization reduce the likelihood and impact of a breach and minimize the associated costs and damage to its reputation.

Furthermore, a likelihood-impact matrix can provide a framework for communication and decision-making among stakeholders. By having a standardized approach to assessing the severity of data breaches, stakeholders can make more informed decisions based on a common understanding of the risks and potential impacts of each breach scenario.

In this study, we discussed that unintended disclosure (DISC), hacking or malware (HACK), fraud involvement around account information (CARD), insiders accessing sensitive information (INSD), loss or stolen assets or records (PHYS), loss of portable media (PORT), and loss of digital equipment such as a desktop computer (STAT) are common types of data breaches that organizations face. Our analyses indicate that data breaches caused by the loss or theft of physical assets or records (PHYS) should be placed into the low-to-medium likelihood and impact quadrant of the matrix. This is due to the relatively low likelihood of occurrence depending on the security measures in place, susceptibility to theft or loss, and other factors, as well as the generally minor impact of such breaches. Therefore, organizations should prioritize their efforts

³ <https://public.tableau.com/app/profile/amir8594/viz/BreachViz-Amir/DataBreachesbyIndustry>

accordingly, focusing on implementing and maintaining appropriate security measures and protocols to prevent or mitigate such breaches. This includes a robust disaster recovery plan that includes off-site recovery, ongoing backups for critical services in geographically diverse locations, and a standby environment ready for deployment in the event of a disaster. It is important to ensure that the organization's critical services can be recovered in a geographically diverse data center, using tools such as disk-to-disk backups and active directory authentication that are spread across multiple physical locations. In addition, organizations should implement secure remote access solutions such as Cisco Adaptive Security Appliance (ASA) and Check Point Secure Socket Layer Virtual Private Networks (SSL VPNs), which provide two-factor authentication for workforce access to internal networks from remote locations. To mitigate the risk of physical location failures, organizations should adopt the N+1 architecture for their critical environmental infrastructure such as power, heating, and cooling. They should also deploy clustered firewall configurations and high availability configurations for physical infrastructures to ensure continuous service delivery even in the event of a resource failure. By prioritizing these security measures and protocols, organizations can significantly reduce the risk of data breaches caused by the loss or theft of physical assets or records.

Our data analysis suggests that the likelihood of an unintended disclosure (DISC) breach is high due to human error, misconfigured systems, or other factors. The impact of such a breach may vary depending on the type of information disclosed, the number of individuals affected, and regulatory requirements. Therefore, this type of breach should be placed in the high-likelihood, low-impact quadrant of the matrix. Organizations should focus on implementing preventive measures to reduce the likelihood of unintended disclosure and minimize the potential impact of such breaches. Furthermore, our findings suggest that breaches caused by insiders accessing sensitive information without authorization (INSD) can have a varying likelihood of occurrence depending on the access controls in place, the awareness of employees about security policies, and other factors. The impact, including the cost of remediation, reputational damage, and legal liabilities, can be moderately significant. Therefore, this type of breach is typically placed in the medium-to-high likelihood, low-to-medium impact quadrant of the matrix. Organizations are recommended to implement a combination of tools and practices, such as Zero Trust framework, identity management processes; access control processes; governance, risk, and compliance (GRC) analytics software; network configuration, data loss protection (DLP), Symantec Endpoint, Active Directory Federation Services, Encase Forensic, and change control services, to mitigate the risk of INSD breaches and minimize their potential impact. In addition, organizations should regularly review and update their security policies, provide training and awareness programs for employees, and enforce strict guidelines for password management and access control.

Based on our analyses, the likelihood of breaches caused by hacking or malware (HACK) can vary depending on the security measures in place, the attractiveness of the organization as a target, and the sophistication of the attackers. The impact can be significant, ranging from the cost of remediation to reputational damage and regulatory penalties. Therefore, this type of breach is typically placed in the high likelihood, high impact quadrant of the matrix. While it is found that hacking and malware attacks by internal or external parties have the highest impact and probability, only 54% of enterprises that are hacked have records that are compromised. To minimize the likelihood and impact of hacking attacks, organizations are recommended to implement a multi-layered approach to mitigate the risk of hacking and malware attacks. This includes using tools such as Rivest-Shamir-Adleman (RSA) secure token authentication, checkpoint firewalls, Symantec data loss protection, and enterprise mobile device management such as AirWatch. Additionally, implementing best practices such as the deny-by-default policy for firewall management, frequent auditing of firewall rule changes, and vulnerability management with manual follow-up,

can further reduce the likelihood of breaches. It is also important to ensure that all employees are trained in cybersecurity best practices and that security measures are regularly updated and tested to stay ahead of emerging threats. By taking a comprehensive approach to cybersecurity, organizations can reduce the likelihood and impact of hacking and malware attacks.

Our results indicate that loss of portable media (PORT) breach type can have a high likelihood depending on the security measures in place, the susceptibility of the portable media to theft or loss, and other factors. However, due to the potential exposure of sensitive data, such as personal health information or financial information, the impact can be medium to high. The loss or theft of portable media can lead to reputational damage, loss of customer trust, and regulatory penalties. Therefore, this type of breach should be regarded as high likelihood and medium-to-high impact, and thus, organizations must implement strict policies and procedures for handling portable media and ensuring the secure transfer and storage of sensitive data. Organizations are also recommended to implement comprehensive data loss prevention tools and practices to mitigate the risk of loss or theft of portable media. These measures may include monitoring for classified data, enforcing whole disk encryption on all mobile devices, and implementing mobile device management for remote wipe and strong password enforcement. It is also important to limit employee access to sensitive data and maintain strong privilege management practices, such as monitoring for unauthorized changes to Active Directory privileges. Additionally, regular training and awareness programs can help prevent human errors and improve the overall security culture. By implementing these measures, organizations can significantly reduce the likelihood and impact of data breaches caused by the loss or theft of portable media.

Our findings suggest that fraud involvement around account information (CARD) has a varying likelihood depending on the security measures in place, the attractiveness of the organization as a target, and the sophistication of the attackers. The impact can be significant, including the cost of fraud prevention and remediation, regulatory penalties, and reputational damage. As such, this type of breach needs to be typically placed in the low-to-medium likelihood and high-impact quadrant of the matrix depending on the amount of information accessed and the extent of the fraud. Therefore, organizations are recommended to implement a multi-layered approach to reduce the risk of data breaches due to credit card fraud. This should include tools such as advanced fraud detection software that can analyze patterns and identify potentially fraudulent transactions in real-time, as well as secure payment processing systems that encrypt cardholder data during transmission and storage. Additionally, companies should implement some practices such as regularly monitoring and reviewing transaction logs for suspicious activity, training employees on how to identify and prevent fraud, and adhering to compliance standards such as the Payment Card Industry Data Security Standards (PCI DSS). By combining these tools and practices, companies can reduce their vulnerability to data breaches caused by credit card fraud and minimize the associated risks and costs.

We found that loss or theft of digital equipment like desktop computers (STAT) can pose a significant risk to organizations, particularly if they contain sensitive information. Therefore, organizations should take appropriate measures to secure their desktop computers and minimize the potential impact of a breach. This includes using full disk encryption to protect all data stored on desktop computers against unauthorized access in the event of theft or loss. Additionally, strong access controls, such as multi-factor authentication and role-based access, ensure that only authorized individuals can access sensitive data. To further minimize vulnerabilities and prevent human errors leading to a breach, it is recommended that organizations keep all software and operating systems up to date with the latest security patches and updates. Regular employee education on security best practices and potential threats, such as phishing and social engineering attacks, can also prevent security incidents. Finally, to detect and prevent malicious

software from infecting desktop computers and other stationary devices, organizations should deploy endpoint protection software, such as antivirus and anti-malware. This can prevent attackers from exploiting vulnerabilities and stealing sensitive information. By implementing these measures, organizations can significantly reduce the likelihood and impact of security incidents involving stationary devices.

In summary, our findings suggest that breaches can vary in their outcomes, with some incidents involving the compromise of sensitive information while others may not directly impact data security. It emphasizes the need for organizations to assess and address all breaches, regardless of whether records were compromised, as each breach poses potential risks and implications for data protection. By acknowledging the diverse nature of breaches, organizations can develop comprehensive strategies and protocols to prevent, detect, and respond to security incidents effectively.

4.1. Limitations and future research

This study is not without limitations. This study only analyzed data breaches that were caused by intentional acts or external factors, while excluding accidental breaches caused by human error or internal programming errors. Over 230 million records were found to be affected by these accidental breaches. Future research can focus on extending the breach level index to account for accidental breaches, enabling a better understanding and response to this type of breach. Businesses can also improve their processes, increase awareness, and provide education to reduce the occurrence of accidental data breaches.

This study did not examine the effectiveness of the actions taken by enterprises to improve their security. It is unclear if the organizations are making significant changes to their security measures after a breach occurs, or if they are simply paying the consequences and continuing with business as usual. Further studies could explore the post-breach response of organizations, including the actions taken by the upper management, such as the CIO or CISO. Future research could also investigate the effectiveness of these actions in preventing prospective breaches. Additionally, exploring the potential benefits of term limits for CISOs could be a worthwhile area of inquiry, as it may provide a fresh perspective and help organizations to avoid complacency from their security measures.

Another limitation of our study is that we did not investigate the role of individual personalities in contributing to data breaches. While it is well-established that human behavior is a significant factor in many breaches, it can be difficult to know which awareness and training programs would be most effective without first understanding the personality characteristics of the individuals involved. Future research could explore this issue by using personality tests to categorize employees based on their risk profiles, and then developing tailored training and awareness programs using neutralization techniques. For more information on this approach, see (Simola, Virtanen & Sartonen, 2019).

Future research could focus on analyzing data breaches in different business sectors beyond just the S&P 500 firms. To provide a more comprehensive understanding of data breaches, it is important to compare and contrast the S&P 500 data breaches with those from other stock market indexes, as well as with small to medium-sized companies. By doing so, researchers can identify similarities and differences in the types of breaches that occur across different industries and organizations. This will help to expand the knowledge base and provide a more nuanced understanding of data breaches and their impact on businesses.

Future research endeavors could extend to the incorporation of additional variables in the regression analysis. Exploring the impact of supplementary predictor variables beyond industry and breach type could enhance the depth and granularity of insights gained from the regression model. By introducing these variables, such as organizational size, geographic location, or specific cybersecurity measures,

researchers can unearth more nuanced relationships and offer a richer understanding of the factors influencing breach severity. This avenue of exploration holds the potential to unravel hidden complexities and contribute to a more comprehensive predictive framework for assessing breach impact.

4.2. Implications for research and practice

This study holds several significant implications for both research and practical applications within the domain of cybersecurity and breach risk management. The outcomes and framework introduced in this study not only advance knowledge but also provide actionable insights for real-world implementation.

From a research perspective, the proposed cybersecurity risk quantification and classification framework lay the groundwork for further exploration of the multifaceted factors that influence breach severity. Future investigations can delve into additional variables, including the influence of individual employee traits, the effectiveness of post-breach responses, and the ever-changing threat landscape. Such endeavors would contribute to a more comprehensive understanding of breach dynamics and enable the development of holistic prevention and mitigation strategies.

Additionally, extending the scope of this study to encompass accidental breaches stemming from human error or internal programming mistakes could provide a more complete view of breach risk. Encompassing accidental breaches in the research scope would facilitate the creation of tailored strategies that address the entire spectrum of breach scenarios, further enhancing the preparedness of organizations. Moreover, the study's analysis of breach severity variations within industries sets the stage for cross-industry comparative examinations. By conducting such studies, researchers could identify shared vulnerabilities and effective mitigation practices across different sectors. This knowledge exchange between industries could foster collaboration and lead to the adoption of more robust cybersecurity measures.

From a practical standpoint, organizations stand to benefit in several ways. The likelihood-impact matrix, a key outcome of the framework, serves as a strategic resource allocation tool. Companies can leverage this matrix to allocate resources effectively for breach prevention and response efforts. By concentrating on breach types characterized by high likelihood and impact, organizations can optimize their investments and bolster overall security readiness. The framework's ability to categorize breach types and industries empowers organizations to tailor their breach response plans to their specific risk profiles. This customization ensures that companies are well-equipped to mitigate the most relevant and impactful breaches, thus amplifying the efficacy of their incident response procedures. Furthermore, for companies operating under industry-specific regulations, the framework provides a means to align breach prevention and response strategies with compliance requirements. By addressing breach types that align with regulatory expectations, organizations can achieve both legal conformity and the safeguarding of sensitive data, preserving stakeholder trust. The study's contributions extend to enhancing stakeholder communication. The standardized breach severity assessment offers a consistent and comprehensible method to communicate potential risks to diverse stakeholders. Organizations can employ this assessment to facilitate meaningful discussions with executive leadership, board members, investors, and regulatory bodies, thereby fostering a deeper appreciation of cybersecurity implications. Lastly, as the threat landscape continues to evolve, organizations can rely on the framework and insights from this study to adapt and enhance their breach prevention and mitigation strategies. By staying attuned to emerging breach types and industry trends, companies can proactively address evolving cybersecurity challenges and maintain a robust security posture.

5. Conclusion

In this study, we proposed a cybersecurity risk quantification and classification framework for evaluating breach severity. Using this framework, we conducted a comprehensive analysis of various types of cybersecurity breaches across different industries, aiming to provide valuable insights for organizations to enhance their risk mitigation strategies. Our framework involved the utilization of breach-level indexing and breach type categorization to quantify and classify breach severity. Additionally, we employed a likelihood-impact matrix as a practical decision analytics tool for prioritizing breach response efforts based on their potential impact and likelihood of occurrence.

Our data analysis revealed intriguing patterns in breach severity across industries and breach types. We presented the mean and standard deviation of the breach level index (BLI) for different industries, highlighting variations in breach severity within each sector. By categorizing breaches into types and industries, we illustrated how different sectors face unique challenges and vulnerabilities. Through regression analysis, we delved deeper into the relationship between breach severity, industry, and breach type. Our findings underscored the importance of considering these factors when evaluating breach risk. We identified sectors with higher and lower severity levels and highlighted the specific breach types that contribute significantly to breach severity.

Furthermore, we constructed a likelihood-impact matrix that provides a visual representation of breach risk levels. By assessing breach probability and impact, organizations can strategically allocate resources and prioritize breach prevention and response strategies. We categorized breach types into quadrants based on their likelihood and impact, offering organizations actionable insights into which breaches demand immediate attention. The discussions of individual breach types emphasized their unique characteristics and risk profiles. We outlined practical measures that organizations can undertake to mitigate the likelihood and impact of different breach types. By tailoring their strategies to specific breach scenarios, organizations can optimize their cybersecurity defenses and minimize potential damages. However, it is important to acknowledge the limitations of this study. We focused

solely on intentional breaches caused by external factors, excluding accidental breaches resulting from human error or internal programming mistakes. Future research could incorporate accidental breaches to provide a comprehensive understanding of breach dynamics. Additionally, investigating post-breach responses and the effectiveness of security measures could offer valuable insights into breach management and prevention strategies. Moreover, the role of individual personalities in contributing to breaches remains unexplored in this study. Understanding the influence of employee traits on breach risk could inform the design of targeted training and awareness programs, enhancing overall cybersecurity culture.

In conclusion, this study contributes to the evolving field of cybersecurity risk assessment by providing a holistic framework for quantifying breach severity and prioritizing breach response efforts. Our findings underscore the importance of industry and breach type considerations in breach management strategies. As the threat landscape continues to evolve, further research in this area will be essential to adapt and refine breach prevention and mitigation strategies for the ever-changing cybersecurity challenges organizations face.

Declaration of competing interest

We declare that the authors have no competing interests, or other interests that might be perceived to influence the results and/or discussion reported in this paper.

Data availability

Data will be made available on request.

Appendix A

See [Table A.6](#).

Appendix B

See [Table B.7](#).

Table A.6
Categorized breach examples with BLI score calculations.

Organization	Number of records breached (N)	Type of data(t)	Breach source (s)	Action (A)	BLI score	Category
TJ Max stores	100,000,000	4 — Social Security Numbers, Account Numbers, Bank Account Information	4 — Outside Malicious	10	10.2	5
J.P Morgan	76,000,000	4 — Social Security Numbers, Account Numbers, Bank Account Information	4 — Outside Malicious	10	9.96	5
The Home Depot	56,000,000	3 — Bank Account Information	4 — Outside Malicious	10	9.83	5
Target Corp	40,000,000	3 — Credit Card Information	4 — Outside Malicious	10	9.68	5
Marriott International	327,000,000	3 — Credit Card Information	4 — Outside Malicious	1	9.59	5
Equifax Corporation	145,500,000	4 — Social Security Numbers	4 — Outside Malicious	1	9.37	5
Anthem	80,000,000	4 — Social Security Numbers	4 — Outside Malicious	1	9.11	5
Under Armor	150,000,000	2 — Account information	4 — Outside Malicious	1	9.08	5
Netflix	100,000,000	2 — Account information	4 — Outside Malicious	1	8.9	4
Facebook	80,000,000	2 — Account information	4 — Outside Malicious	1	8.81	4

Table B.7
Exemplary instances of data cleaning and classification: Three specific breach cases and utilized resources.

Date made public	Organization	Number of records breached	Year of breach	Breach type	Resources
8/2/2018	American Express Travel Related Services Company, Inc.	500	2018	HACK	California Attorney General. (2018). Customer Notification. Retrieved from https://oag.ca.gov/system/files/Customer%20Notification%20C1807014816_1.pdf . The breach notification details highlight a potential intrusion into a booking platform, posing a risk to personal information including full name, payment card details, and email address. This scenario corresponds with the Hacking or Malware (HACK) breach type, which involves unauthorized intrusions into systems or platforms, potentially resulting in the exposure of sensitive customer data.
8/10/2018	JPMorgan Chase Bank, Inc.	500	2018	DISC	California Attorney General. (2018). Customer Notice. Retrieved from https://oag.ca.gov/system/files/2018_8_10_CCB_customer_notice_CA_0.pdf . The breach description indicates that a Chase employee improperly downloaded customer information onto personal devices and online data storage sites, potentially exposing it to third parties. This scenario closely corresponds to the Unauthorized Disclosure (DISC) breach type, which involves the unauthorized or improper sharing and exposure of sensitive information.
2/14/2018	PACCAR Inc.	251	2018	PORT	Indiana Attorney General. (2018). Customer Notice. Retrieved from https://www.doj.in.gov/consumer/security-reaches/documents/paccar-20180214.pdf . The breach description mentions that the breach involved a stolen laptop and thumb drive containing sensitive information. This aligns with the Portable Media (PORT) breach type, which involves the loss or theft of portable devices such as laptops, or other storage media.

References

- [1] A. Kuzior, P. Brożek, O. Kuzmenko, H. Yarovenko, T. Vasilyeva, Countering cybercrime risks in financial institutions: Forecasting information trends, *J. Risk Financ. Manag.* 15 (12) (2022) 613.
- [2] L. Ponemon, Ponemon institute cost of a data breach study, 2016.
- [3] S. Jackson, N. Vanteeva, C. Fearon, An investigation of the impact of data breach severity on the readability of mandatory data breach notification letters: Evidence from US firms, *J. Assoc. Inf. Sci. Technol.* 70 (11) (2019) 1277–1289.
- [4] A.H. Zadeh, A. Jeyaraj, D. Biros, Characterizing cybersecurity threats to organizations in support of risk mitigation decisions, *e-Service J.* 12 (2) (2020) 1–34.
- [5] M. Someya, Resolving data breach dispute: Automated negotiation, e-mediation, and arbitration assisted by technology, *Ohio St. J. on Disp. Resol.* 34 (2019) 393.
- [6] R. Ayyagari, An exploratory analysis of data breaches from 2005–2011: trends and insights, *J. Inf. Privacy Secur.* 8 (2) (2012) 33–56.
- [7] S. Goel, H.A. Shawky, Estimating the market impact of security breach announcements on firm values, *Inf. Manag.* 46 (7) (2009) 404–410.
- [8] B. Sheehan, F. Murphy, A.N. Kia, R. Kiely, A quantitative bow-tie cyber risk classification and assessment framework, *J. Risk Res.* 24 (12) (2021) 1619–1638.
- [9] R.C. Thomas, M. Antkiewicz, P. Florer, S. Widup, M. Woodyard, How bad is it?—A branching activity model to estimate the impact of information security breaches. A branching activity model to estimate the impact of information security breaches (March 11, 2013), 2013.
- [10] F. Schlackl, N. Link, H. Hoehle, Antecedents and consequences of data breaches: A systematic review, *Inf. Manag.* (2022) 103638.
- [11] Z. Aivazpour, R. Valecha, R. Chakraborty, The impact of data breach severity on post-breach online shopping intention, 2018.
- [12] S. Gerić, Ž. Hutinski, Information system security threats classifications, *J. Inf. Organ. Sci.* 31 (1) (2007) 51–61.
- [13] C.-W. Liu, P. Huang, H.C. Lucas Jr., Centralized IT decision making and cybersecurity breaches: Evidence from US higher education institutions, *J. Manage. Inf. Syst.* 37 (3) (2020) 758–787.
- [14] A. Jeyaraj, A.H. Zadeh, Exploration and exploitation in organizational cybersecurity, *J. Comput. Inform. Syst.* 62 (4) (2022) 680–693.
- [15] S. Das, A. Mukhopadhyay, D. Saha, S. Sadhukhan, A markov-based model for information security risk assessment in healthcare MANETs, *Inf. Syst. Front.* 21 (2019) 959–977.
- [16] K. Sharma, A. Mukhopadhyay, Kernel naïve Bayes classifier-based cyber-risk assessment and mitigation framework for online gaming platforms, *J. Organ. Comput. Electron. Commerce* 31 (4) (2021) 343–363.
- [17] J.C. Westland, Predicting credit card fraud with Sarbanes-Oxley assessments and Fama–French risk factors, *Intell. Syst. Account., Finance Manag.* 27 (2) (2020) 95–107.
- [18] B. Biswas, A. Mukhopadhyay, S. Bhattacharjee, A. Kumar, D. Delen, A text-mining based cyber-risk assessment and mitigation framework for critical analysis of online hacker forums, *Decis. Support Syst.* 152 (2022) 113651.
- [19] A. McLeod, D. Dolezel, Cyber-analytics: Modeling factors associated with healthcare data breaches, *Decis. Support Syst.* 108 (2018) 57–68.
- [20] M. Tavana, A.K. Nasr, A.B. Ahmadiabadi, A.S. Amiri, H. Mina, An interval multi-criteria decision-making model for evaluating blockchain-IoT technology in supply chain networks internet of things, 22 (2023) 100786.
- [21] J. Lee, M.C. de Guzman, J. Wang, M. Gupta, H.R. Rao, Investigating perceptions about risk of data breaches in financial institutions: A routine activity-approach, *Comput. Secur.* 121 (2022) 102832.
- [22] L.I. Labrecque, E. Markos, K. Swani, P. Peña, When data security goes wrong: Examining the impact of stress, social contract violation, and data type on consumer coping responses following a data breach, *J. Bus. Res.* 135 (2021) 559–571.
- [23] A.H. Juma'h, Y. Alnsour, The effect of data breaches on company performance, *Int. J. Account. Inf. Manag.* (2020).
- [24] A. Zadeh, A. Jeyaraj, A multistate modeling approach for organizational cybersecurity exploration and exploitation, *Decis. Support Syst.* 162 (2022) 113849.
- [25] A. Jeyaraj, A. Zadeh, V. Sethi, Cybersecurity threats and organisational response: Textual analysis and panel regression, *J. Bus. Anal.* 4 (1) (2021) 26–39.

- [26] L.A. Gordon, M.P. Loeb, T. Sohail, C.-Y. Tseng, L. Zhou, Cybersecurity, capital allocations and management control systems, *Eur. Account. Rev.* 17 (2) (2008) 215–241.
- [27] A. Jeyaraj, A. Zadeh, Institutional isomorphism in organizational cybersecurity: A text analytics approach, *J. Org. Comput. Electron. Commer.* 30 (4) (2020) 361–380.
- [28] J.C. Chou, Cybersecurity, identity theft, and standing law: A framework for data breaches using substantial risk in a post-clapper world, *Nat'l Sec. L. Brief* 7 (2017) 120.
- [29] D. Kolevski, K. Michael, R. Abbas, M. Freeman, Cloud data breach disclosures: The consumer and their personally identifiable information (PII)? in: 2021 IEEE Conference on Norbert Wiener in the 21st Century, 21CW, IEEE, 2021.
- [30] T. Webb, S. Dayal, Building the wall: Addressing cybersecurity risks in medical devices in the USA and Australia, *Comput. Law Secur. Rev.* 33 (4) (2017) 559–563.
- [31] A. Strielkina, D. Uzun, V. Kharchenko, A. Tetskyi, Modeling and availability assessment of mobile healthcare IoT using tree analysis and queueing theory, in: Dependable IoT for Human and Industry, River Publishers, 2022, pp. 105–126.
- [32] M. Tavana, *Decision Analytics in the World of Big Data and Colorful Choices*, Elsevier, 2021, p. 100002.
- [33] E. Africk, Y. Levy, An examination of historic data breach incidents: What cybersecurity big data visualization and analytics can tell us? *Online J. Appl. Knowl. Manag. (OJAKM)* 9 (1) (2021) 31–45.
- [34] M. Tripathi, A. Mukhopadhyay, Does privacy breach affect firm performance? An analysis incorporating event-induced changes and event clustering, *Inf. Manag.* 59 (8) (2022) 103707.
- [35] E.D. Madyatmadja, A.N. Hakim, D.J.M. Sembiring, Performance testing on transparent data encryption for SQL server's reliability and efficiency, *J. Big Data* 8 (2021) 1–14.
- [36] C.H. Lee, X. Geng, S. Raghunathan, Mandatory standards and organizational information security, *Inf. Syst. Res.* 27 (1) (2016) 70–86.
- [37] J. Chen, E. Henry, X. Jiang, Is cybersecurity risk factor disclosure informative? Evidence from disclosures following a data breach, *J. Bus. Ethics* (2022) 1–26.
- [38] F.T. Commission, *Data breach response: A guide for business* (2021), 2021.
- [39] S. Kierkegaard, Data insecurity: scams, blags & scalawags. The secure information society: ethical, legal and political challenges, 2013, pp. 117–134.
- [40] P. Kierkegaard, Medical data breaches: Notification delayed is notification denied, *Comput. Law Secur. Rev.* 28 (2) (2012) 163–183.
- [41] M. Burdon, B. Lane, P. Von Nessen, The mandatory notification of data breaches: Issues arising for Australian and EU legal developments, *Comput. Law Secur. Rev.* 26 (2) (2010) 115–129.
- [42] S. Wheatley, A. Hofmann, D. Sornette, Addressing insurance of data breach cyber risks in the catastrophe framework, *Geneva Pap. Risk Insurance-Issues Pract.* 46 (2021) 53–78.
- [43] K. Jung, Extreme data breach losses: An alternative approach to estimating probable maximum loss for data breach risk, *North Am. Actuarial J.* 25 (4) (2021) 580–603.
- [44] M. Barati, B. Yankson, Predicting the occurrence of a data breach, *Int. J. Inf. Manag. Data Insights* 2 (2) (2022) 100128.
- [45] L. Bohn, D. Schiereck, Regulation of data breach publication: The case of US healthcare and the HITECH act, *J. Econ. Finance* 47 (2) (2023) 386–399.
- [46] N.N. Neto, S. Madnick, A.M.G.D. Paula, N.M. Borges, Developing a global data breach database and the challenges encountered, *J. Data Inf. Qual. (JDIQ)* 13 (1) (2021) 1–33.
- [47] Y. He, E.D. Zamani, S. Lloyd, C. Luo, Agile incident response (AIR): Improving the incident response process in healthcare, *Int. J. Inf. Manag.* 62 (2022) 102435.
- [48] H.S. Chen, T.-M. Jai, Trust fall: Data breach perceptions from loyalty and non-loyalty customers, *Serv. Ind. J.* 41 (13–14) (2021) 947–963.
- [49] R. Stiennon, *Categorizing data breach severity with a breach level index*, 2013, URL: <https://breachlevelindex.com/pdf/Breach-Level-Index-WP.pdf>.
- [50] E.W. Ayaburi, Understanding online information disclosure: Examination of data breach victimization experience effect, *Inf. Technol. People* 36 (1) (2023) 95–114.
- [51] A.H. Zadeh, R. Sharda, Modeling brand post popularity dynamics in online social networks, *Decis. Support Syst.* 65 (2014) 59–68.
- [52] P. Rosati, T. Lynn, A dataset for accounting, finance and economics research on US data breaches, *Data Brief* 35 (2021) 106924.